

Compliance Assessment Summary

Assessment Date: 2026-02-17 | Industry: E-Commerce | Jurisdiction: US, California

Scenario

A California-based e-commerce startup is integrating Apple Pay as its primary payment method with Stripe credit card processing as fallback. The company serves US customers only (including California), has a 20-person team, and handles no healthcare data, AI features, or government contracts.

Applicable Frameworks

Framework	Status	Key Obligation
PCI DSS v4.0	Mandatory	Secure card payment processing
CCPA/CPRA	Mandatory	Consumer data privacy rights
SOC 2 Type II	Recommended	Security attestation for customers
NIST CSF 2.0	Recommended	Cybersecurity risk management

Key Findings

1. **(Critical)** PCI DSS v4.0 payment page script controls (Req. 6.4.3, 11.6.1) are now fully mandatory — most startups lack these controls.
2. **(High)** CCPA/CPRA requires a published privacy policy, data rights request process, and opt-out mechanism if third-party tracking is used.
3. **(High)** Stripe and Apple Pay tokenization significantly reduce PCI scope but do not eliminate compliance obligations — SAQ completion is still required.
4. **(Medium)** No formal security program documentation (policies, incident response, training) exists — needed for both PCI DSS and SOC 2.
5. **(Medium)** Cross-framework control mapping shows a single IAM, logging, and incident response implementation can satisfy all four frameworks.

Priority Actions

1. **Engineering (0–30 days):** Confirm Stripe integration type, inventory payment page scripts, implement CSP/SRI, and submit PCI DSS SAQ.
2. **Legal + Engineering (0–60 days):** Publish CCPA-compliant privacy policy, implement data rights request process, and complete data inventory.
3. **Engineering + Security (30–90 days):** Deploy MFA on all admin access, centralized logging, incident response plan, and security awareness training.